

Vulnerability Assessment Report

Intern Name: Cinchana S

Target : OWASP Mutilidae

Environment: Local lab setup using VirtualBox

Tools Used: Kali Linux, nmap, OWASP ZAP, Canva

Table of Contents:

1. Executive Summary
2. Scope and Environment
3. Technical Details
4. Risk Matrix
5. Ethical Disclaimer

Executive Summary

This vulnerability assessment was done in a controlled lab setting using Metasploitable2, a virtual machine designed to be insecure. The testing focused on the **Mutillidae web application**, which runs on Metasploitable2. During the assessment, several serious vulnerabilities were found in Mutillidae, such as **SQL Injection, Path Traversal, and Reflected Cross-Site Scripting (XSS)**. To evaluate the risks of these vulnerabilities, each was scored using the CVSS v3.1 system, which rates security weaknesses. Furthermore, the vulnerabilities were organized based on how likely they were to be exploited versus the potential impact they could cause using a risk matrix. Overall, this assessment provided important insights into the security weaknesses present in the tested environment. The findings demonstrate common real-world security weaknesses and emphasize the importance of secure configuration and coding practices.

Scope & Environment

The scope of this assessment was limited to a local lab environment consisting of Kali Linux as the attacker machine. Web exploitation activities were conducted exclusively against the **Mutillidae web application** running on Metasploitable2. No production or external systems were targeted during this assessment.

Technical Details

Vulnerability 1: SQL Injection (MySQL)

Application: Mutillidae

CWE ID: 89

CVSS Score: 9.8 (Critical)

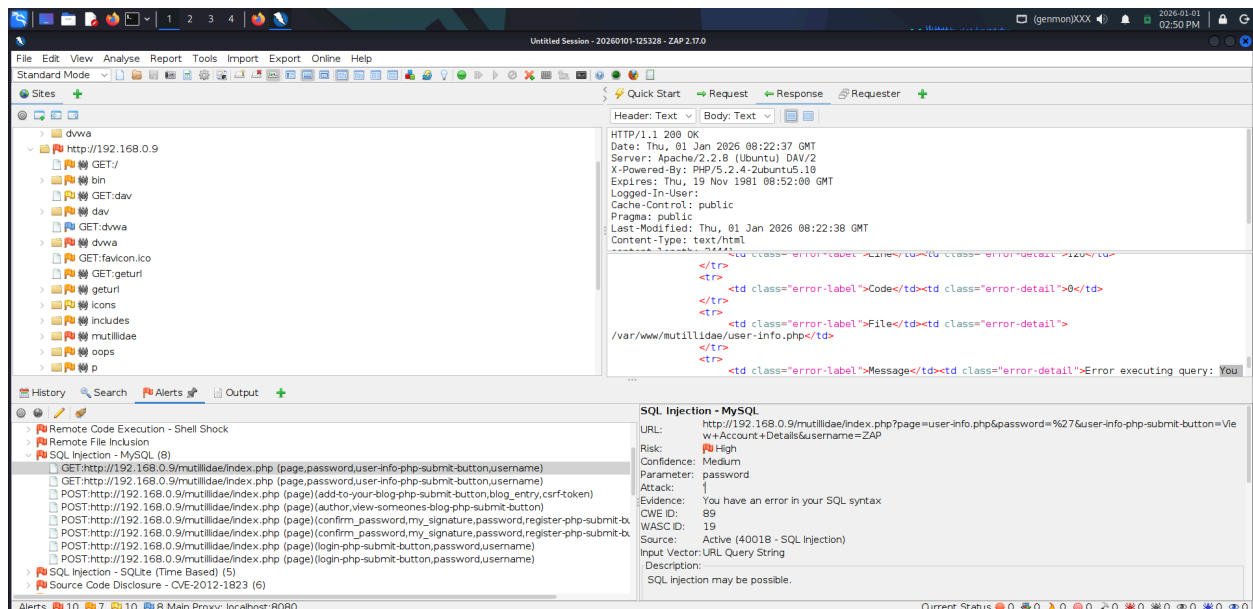
Risk Level: High

Description: A SQL Injection vulnerability was identified in the Mutillidae web application hosted on Metasploitable2. Improper input validation allows attackers to inject malicious SQL queries into backend MySQL database queries, potentially leading to unauthorized data access or full database compromise.

Evidence:

The Vulnerability was found in the following url

<http://192.168.0.9/mutillidae/index.php?page=user-info.php&password=%27&user-info-php-submit-button=View+Account+Details&username=ZAP>



OWASP ZAP screenshot showing SQL Injection in Mutillidae

The risks of this vulnerability:

1. Extraction of Sensitive Data
2. Database Enumeration and Manipulation

Remediation:

1. Use of prepared statements with parametrized queries to ensure the separation of code and data
2. Regular expression checks on input data to prevent the injection of unwanted SQL tokens.
3. Error Handling to ensure that error messages do not disclose sensitive information about the database structure.
4. Deploying a WAF that can detect and block SQL injection attempts.

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Vulnerability 2: Reflected XSS

Application: Mutillidae (on Metasploitable2)

CWE ID: 79

CVSS Score: 6.1 (High)

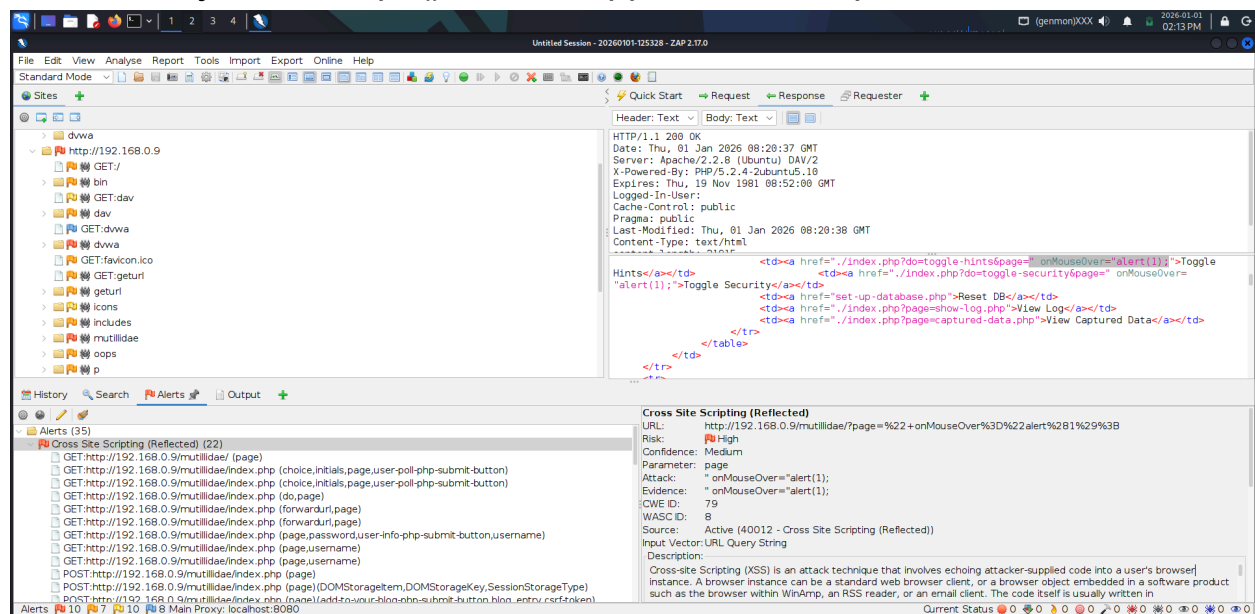
Description: A reflected XSS vulnerability was discovered in Mutillidae. Malicious JavaScript injected through user input is reflected in the server response and executed in the victim's browser, potentially leading to session hijacking or unauthorized actions.

Evidence:

The Vulnerability was found in the following url

`http://192.168.0.9/mutillidae/index.php?choice=nmap&initials=ZAP&page=">&user-poll-php-submit-button=Submit+Vote`

This URL injects a script () into the application's response.



The risks of this vulnerability:

1. Stealing Cookies and Phishing
2. Executing Malicious Scripts
3. Bypassing CSRF Protections

Remediation:

1. Ensuring all user input is properly sanitized before being reflected back in output.
2. Implementing a robust CSP to prevent the execution of unauthorized scripts.
3. Escape all user-controlled data based on the context in which it's displayed (HTML, JavaScript, CSS, URL, etc.).

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Vulnerability 3: Path Traversal

Application: Mutillidae (on Metasploitable2)

CWE ID: 22

CVSS Score: 7.5 (High)

Description: Path Traversal, is an attack which allows attackers to access files and directories that are stored outside the web application's root directory. Attackers manipulate variables that reference files with ../ sequences and similar methods, attempting to access files and directories stored on the server file system.

Evidence:

The Vulnerability was found in the following url

<http://192.168.0.9/mutillidae/index.php?do=toggle-security&page=%2Fetc%2Fpasswd>

The screenshot displays the Burp Suite interface during a security scan. The top pane shows the 'Sites' tab with a tree view of the scanned site, including directories like 'bin', 'dwa', 'icons', and 'mutillidae'. The middle pane shows the 'Request' tab for a GET request to the URL `http://192.168.0.9/mutillidae/index.php?do=toggle-security&page=%2Fetc%2Fpasswd`. The response body contains HTML code, including a `<div>` tag with a `href` attribute pointing to the same URL. The bottom pane shows the 'Alerts' tab, which lists several detected vulnerabilities. The 'Path Traversal' alert is highlighted, showing details such as the URL, risk level (High), confidence (Medium), parameter (page), attack (etc/passwd), evidence (root:x00), WASC ID (33), source (Active (6 - Path Traversal)), alert reference (6-2), and input vector (URL Query String). The description of the alert states: 'The Path Traversal attack technique allows an attacker access to files, directories, and commands that potentially reside outside the web document root directory. An attacker may manipulate a URL in such a way that the web site will execute'.

The risks of this vulnerability:

1. Exposure of Sensitive Data
2. Information Leakage and Potential for Further Exploitation
3. System Compromise

Remediation:

1. Implementing strict validation of user-supplied input, rejecting any suspicious or malformed input.
2. Employing a safelist of allowed files and deny access to any file not on the list.
3. Ensuring the web application runs with the least privileges necessary, limiting the files that can be accessed.
4. Using file handling APIs that inherently manage path traversal vulnerabilities.

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:L/A:N

Risk Matrix:

Likelihood\Impact	Low	Medium	High
High	—	—	SQL Injection
Medium	—	Reflected XSS	Path Traversal
Low	—	—	—

3×3 Risk Matrix illustrating prioritization of identified vulnerabilities based on likelihood and impact.

Ethical Disclaimer:

All exploitation activities were conducted solely on the Mutillidae web application, which are intentionally vulnerable and designed for security testing and learning purposes.